Continued…

The Threat Environment: Attackers and Their Attacks

Reference:

Corporate & Network Security, Chapter 1

Raymond R. Panko

Agenda

- The threat environment—attackers and their attacks
- Basic security terminology
- Employee and ex-employee threats
- Traditional external attackers
- The criminal era and competitor threats
- Cyberwar and cyberterror

Copyright Pearson Prentice-Hall 2010

Traditional External Attackers: 2.3.4 Hackers

- **Traditional Hackers**

In the 1970s, malware writers were joined by external hackers who began to break into corporate computers that were connected to modems. Today nearly every firm is connected to the Internet which harbors millions of external hackers

Copyright Pearson Prentice-Hall 2010

Traditional External Attackers: Hackers

- **Traditional Hackers**
  - Motivated by thrill, validation of skills, sense of power
  - Motivated to increase reputation among other hackers
  - Often do damage as a byproduct
  - Often engage in petty crime

ComputerWeekly.com 2008

Copyright Pearson Prentice-Hall 2010

Traditional External Attackers: Hackers

- **Traditional Hackers**

In 2009, vandals broke into a computerized road sign in Austin, Texas, and changed its message to read: “The end is near ! Caution ! Zombies Ahead !”

Dallasnews.com, January 2009

Raymond Torricelli, broke into NASA computers and used up processor time, money, and disk resources to divert chat users to a website for which he admitted to being paid USD 400 per week.

Cybercrime.gov, 2001

Traditional External Attackers: Hackers

Just like a thief who wants to rob a home does reconnaissance of the neighborhood and gathers information to determine which house to break into, hackers also tend to do reconnaissance before breaking into a computer.

As the figure shows, the attacker often sends probe packets into a network. These probe packets are designed to elicit replies from internal hosts and routers.

Copyright Pearson Prentice-Hall 2010

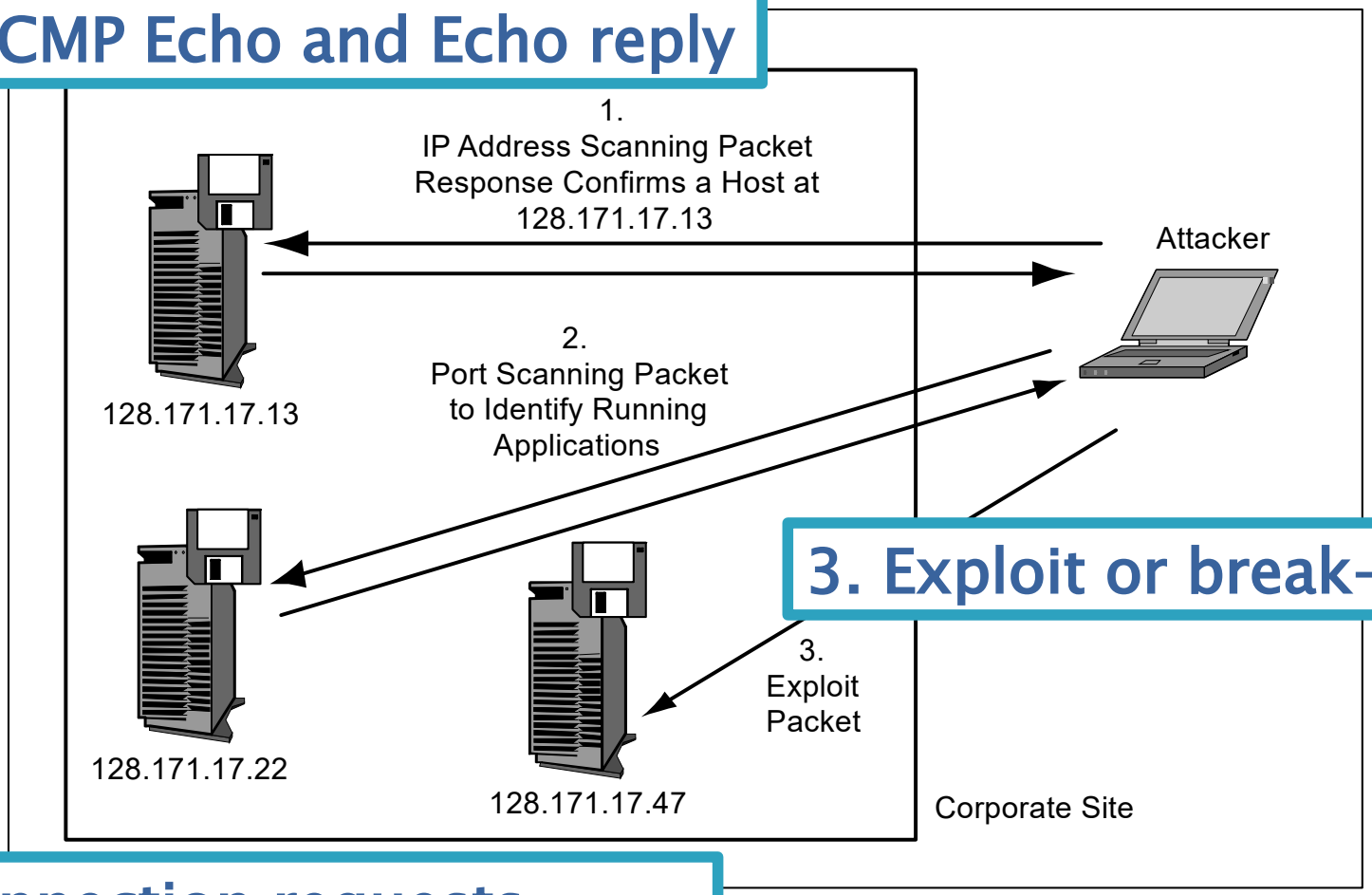
Traditional External Attackers: Hackers

- **Anatomy of a Hack**
  - Reconnaissance probes (see figure)
    - IP address scans to identify possible victims
      - Identify active hosts
      - ICMP Echo and Echo reply messages
    - Port scans (connection requests) to learn which services are open on each potential victim host

Port 80 is the well known port for HTTP web servers. There are many well known port numbers between 0 and 1023. each indicates the presence of a particular type of application.

Copyright Pearson Prentice-Hall 2010

Probe and Exploit Attack Packets



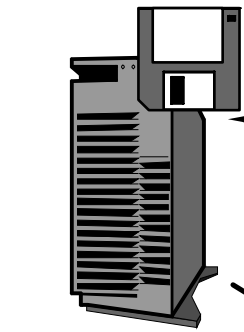
Copyright Pearson Prentice-Hall 2010

Traditional External Attackers: Hackers

- **Anatomy of a Hack**
  - The exploit
    - The specific attack method that the attacker uses to break into the computer is called the attacker's exploit
    - The act of implementing the exploit is called exploiting the host

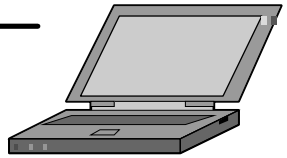
Copyright Pearson Prentice-Hall 2010

Source IP Address Spoofing



128.171.17.13

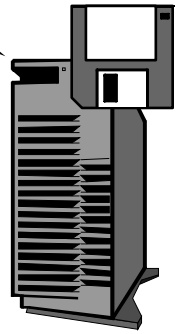
Attacker



10.6.4.3

1.
Spoofed Packet to 128.171.17.13
Source IP address = 128.171.17.47
Instead of 10.6.4.3

2.
Reply goes to
Host 128.171.17.47



128.171.17.47

IP Address Spoofing
Hides the Attacker's Identity.

But Replies do Not Go to the Attacker,
So IP address Spoofing
Cannot be Used for All Purposes

Some exploit packets cannot be spoofed so the attacker uses chain of attack

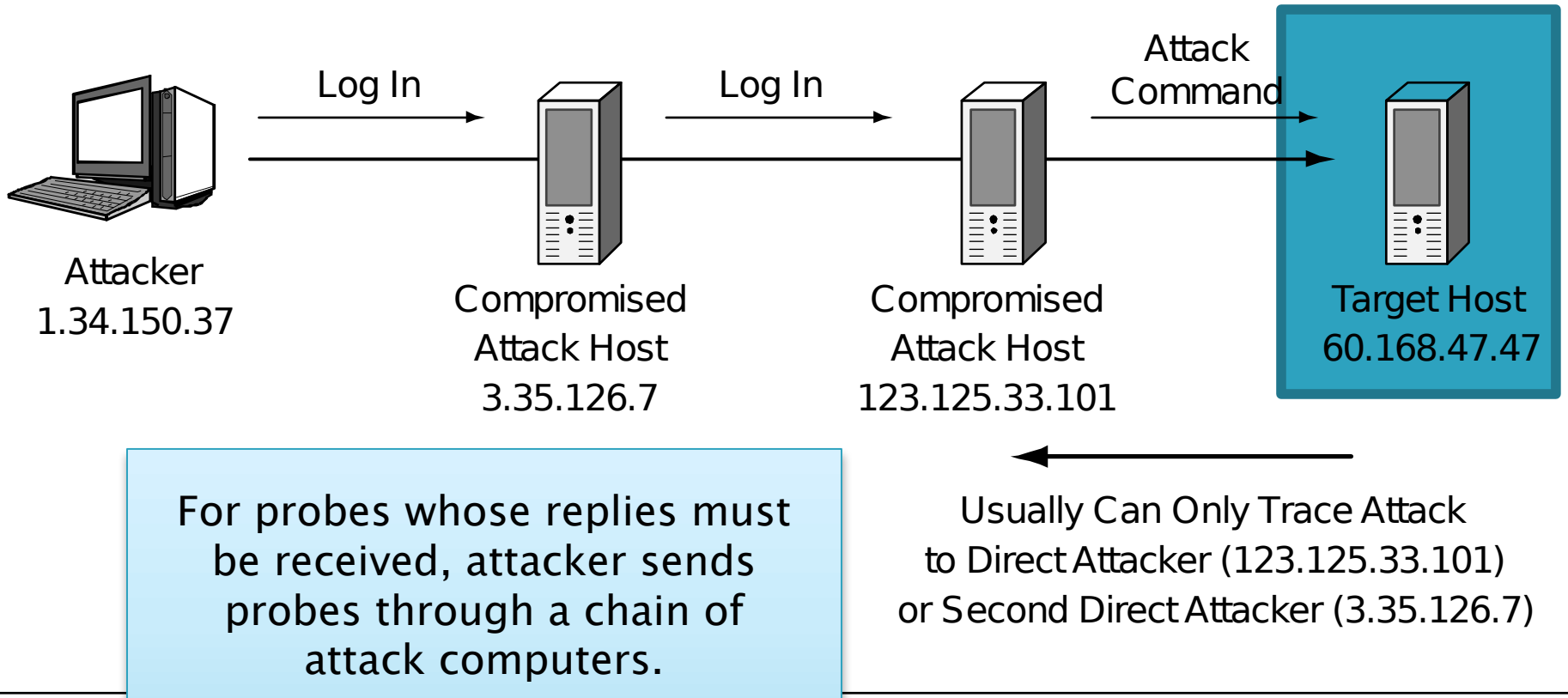
Copyright Pearson Prentice-Hall 2010

Traditional External Attackers: Hackers

- **Chain of attack computers (see figure)**
  - The attacker attacks through a chain of victim computers
  - Probe and exploit packets contain the source IP address of the last computer in the chain
  - The final attack computer receives replies and passes them back to the attacker
  - Often, the victim can trace the attack back to the final attack computer
  - But the attack usually can only be traced back a few computers more

Copyright Pearson Prentice-Hall 2010

1-10: Chain of Attack Computers



For probes whose replies must be received, attacker sends probes through a chain of attack computers.

Victim only knows the identity of the last compromised host (123.125.33.101)

Not that of the attacker

Copyright Pearson Prentice-Hall 2010

Traditional External Attackers: Hackers

- **Social Engineering**
  - Social engineering is often used in hacking
  - Social engineering (as we saw earlier) is attempting to trick users into doing something that goes against the interests of security
  - Often successful because it focuses on human weaknesses instead of technological weaknesses

Copyright Pearson Prentice-Hall 2010

Traditional External Attackers: Hackers

- **Social Engineering**
  - Call and ask for passwords and other confidential information

In one social engineering ploy, a hacker calls a secretary claiming to be working with the secretary's boss. The hacker then asks for sensitive information such as a password or sensitive file.

Copyright Pearson Prentice-Hall 2010

Traditional External Attackers: Hackers

- **Social Engineering**

In one study, US Treasury Dept. inspectors posing as computer technicians called 100 Internal Revenue Service (IRS) employees and managers. The treasury agents asked each target for his or her username and asked the user to change the password to a specific password chosen by the "technician." This was a clear violation of policy but 35% fell for the ploy in 2005.

Washington Post, March 2005

Copyright Pearson Prentice-Hall 2010

Traditional External Attackers: Hackers

- **Social Engineering**
  - E-mail attack messages with attractive subjects
  - Piggybacking
  - Shoulder surfing
  - Pretexting

Piggybacking is following someone through a secure door, without entering a pass code. Looking over someone's shoulder when he or she types a password is shoulder surfing. In pretexting the attacker calls claiming to be a certain customer in order to get private information about that customer.

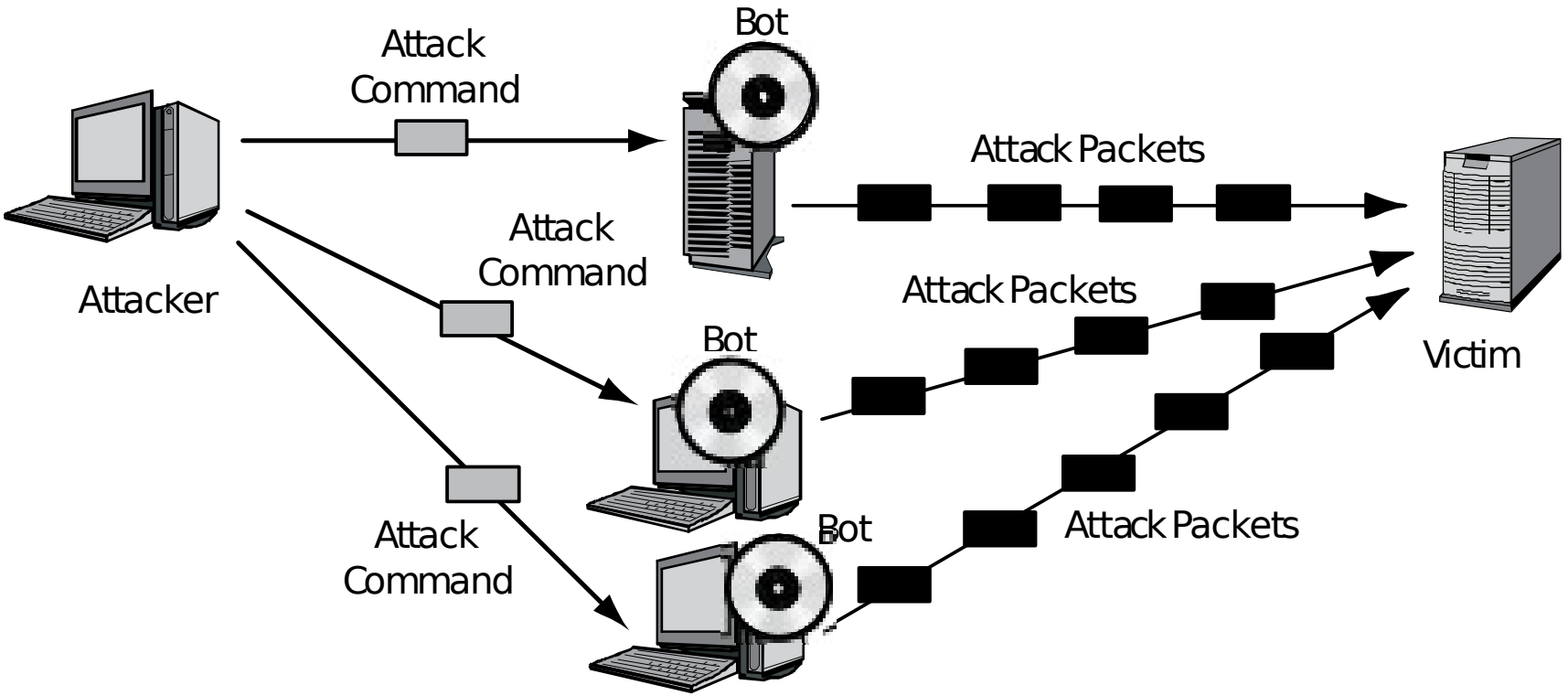
Copyright Pearson Prentice-Hall 2010

Traditional External Attackers: Hackers

- **Denial-of-Service (DoS) Attacks**
  - Make a server or entire network unavailable to legitimate users
  - Typically send a flood of attack messages to the victim
  - Distributed DoS (DDoS) Attacks (see figure)
    - Bots flood the victim with attack packets
    - Attacker controls the bot

Copyright Pearson Prentice-Hall 2010

Distributed Denial-of-Service (DDoS) Flooding Attack



Copyright Pearson Prentice-Hall 2010

Distributed Denial-of-Service (DDoS) Flooding Attack

In 2001, the Code Red virus attacked the US Whitehouse website. Fortunately the attacks were made against the website's IP address in stead of its host name. The White House merely changed the IP address of whitehouse.gov

To attack a server, the bots might flood the server with TCP connection-opening requests (TCP SYN segments). A server reserves a certain amount of capacity each time it receives a SYN segment. By flooding a computer with SYN segments, the attacker can cause the server to run out of resources and therefore crash.

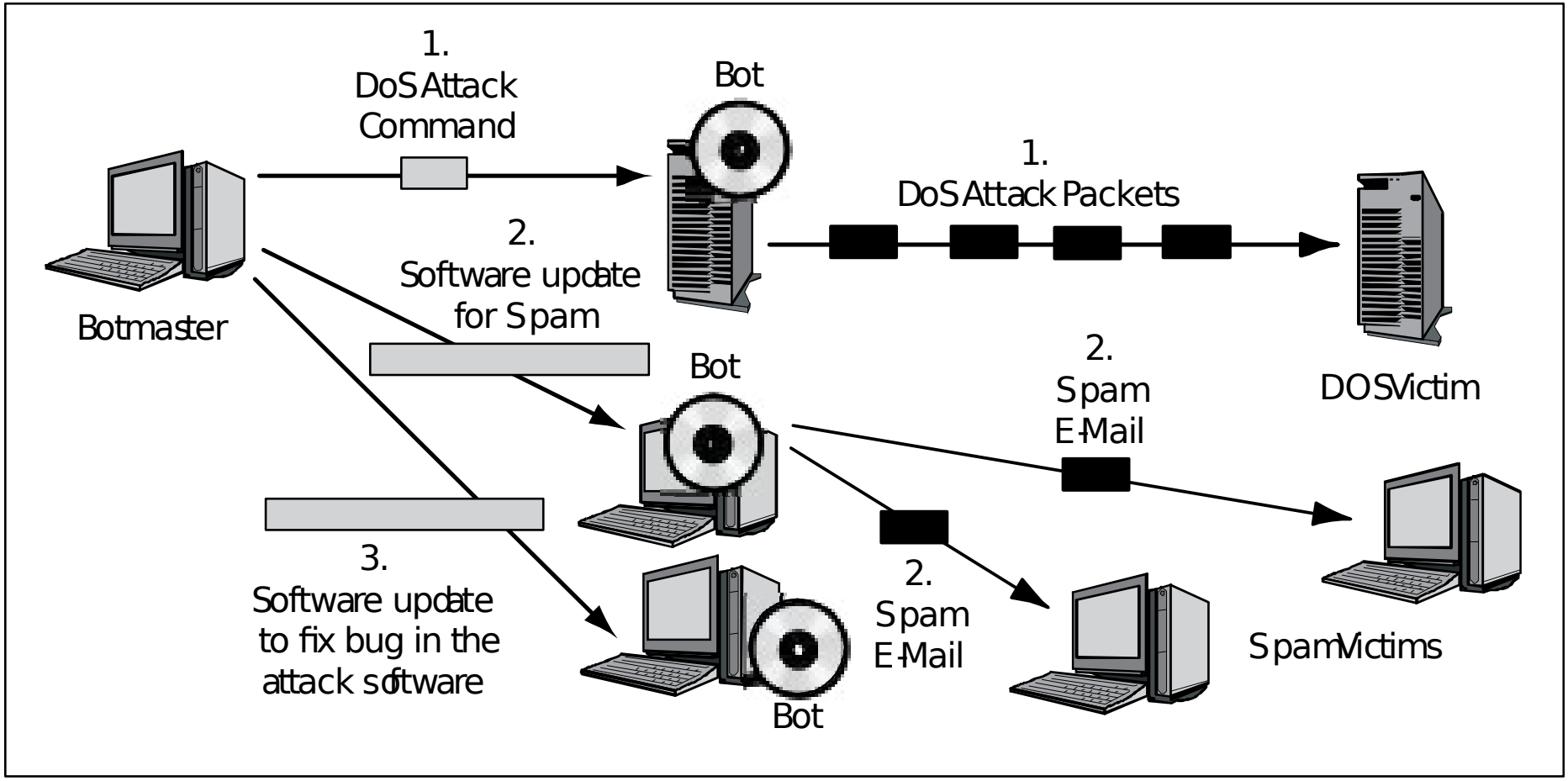
Copyright Pearson Prentice-Hall 2010

Traditional External Attackers: Hackers

- **Bots**
  - Updatable attack programs (see figure)
  - Botmaster can update the software to change the type of attack the bot can do
    - May sell or lease the botnet to other criminals
  - Botmaster can update the bot to fix bugs

Copyright Pearson Prentice-Hall 2010

Fixing and Updating Bots



Copyright Pearson Prentice-Hall 2010

Traditional External Attackers: Hackers

- **Bots**

Jeanson Ancheta was indicted for crimes involving a large botnet. Ancheta was charged with creating the botnet and installing adware programs, which constantly pop up advertisements, on these computers for a fee. He was also charged with renting parts of his botnet to other criminals for spam and denial of service attacks.

http://www.cybercrime.gov (Nov 2005)

Copyright Pearson Prentice-Hall 2010

Traditional External Attackers: Hackers

- **Skill Levels**
  - Expert attackers are characterized by strong technical skills and dogged persistence
  - Expert attackers create hacker scripts to automate some of their work
  - Scripts are also available for writing viruses and other malicious software

Todays hacker scripts often have easy to use graphical user interfaces and look like commercial products. Many scripts are available on the Internet…These easy to use scripts have created a new type of hacker "the script kiddie"

Copyright Pearson Prentice-Hall 2010

Traditional External Attackers: Hackers

- **Skill Levels**
  - Script kiddies use these scripts to make attacks
  - Script kiddies have low technical skills
  - Script kiddies are dangerous because of their large numbers

In February 2000 a number of major firms were affected by devastatingly effective DDOS attacks that blocked each of their e-commerce systems for hours at a time. Victims included CNN, ebay, Yahoo, ZDNET, and others. At first the attacks were thought to be work of an elite hacker. However, the culprit was found to be a 15 year old script kiddie in Canada

Copyright Pearson Prentice Hall 2010

Traditional External Attackers: Hackers

- **Skill Levels**

Virus and other Malware writers also have written long programs for creating new malware. Viruses have become so easy to create with these tools that Svan Jaschan, an 18 year old German student, who had never written a virus before, was responsible for 70% of the virus activity in the first half of 2004. (http://www.sophos.com)

Copyright Pearson Prentice-Hall 2010

Traditional External Attackers: Hackers

- **Skill Levels**

Today tools are available for creating all types of exploits. One of the most important is the MetaSploit Framework which makes it easy to take a new exploitation method and rapidly turn it into a full attack program. Metasploit is used both by attackers to launch attacks, and by security professionals to test the vulnerability of their systems to specific exploits.
(http://www.metasploit.com)

Copyright Pearson Prentice-Hall 2010